概念性文章（研究框架）· 2026年10月18日

人工智能在SOC告警分诊中的应用

IT卫生、零信任与工具碎片化的调节作用

Innocent Twagirumukiza

摘要

人工智能（AI）对安全运营中心（SOC）告警分诊的影响，取决于其部署环境的质量。本文提出一个概念框架来检验这一命题。其研究问题是：IT卫生成熟度、零信任实施的一致性以及工具碎片化程度，是否以及如何改变AI相对于传统分诊在检测质量和调查成本上的效果。

该框架区分信息量与信息噪声。它将AI的使用视为核心变量，将上述三个因素视为调节变量，将告警数量和规则配置复杂度视为控制变量。文章提出四项研究命题，每项均给出预期方向及其反驳标准。同时提出一个两阶段的验证方案：先进行探索性定性研究，再进行多层次分析，并辅以对已标注告警的回放。

本文不报告任何实证结果。其目的是提供一个可检验的基础，以确定在何种条件下AI能够真正减少信息噪声，而不是将既有缺陷自动化。

关键词： SOC，告警分诊，信息噪声，人工智能，IT卫生，零信任，工具碎片化，调节效应，人的决策。

1. 引言

SOC集中承担监控、检测、分析和事件响应工作。它们依托安全事件管理、终端检测、威胁情报和响应编排等解决方案。云环境的增多、数字身份的普及以及遥测数据源的增长，使需要处理的数据量不断增加，而各组织则不断叠加专用工具，以覆盖日益扩大的范围。

文献描述了这种状况对人造成的后果。Tariq等人（2025）综述了SOC中告警疲劳的研究现状。Alahmadi等人（2022）和Kokulu等人（2019）通过对分析员的访谈，报告了与告警相关性以及工具、流程和人员之间匹配度有关的困难。Vielberth等人（2020）对SOC及其尚未解决的挑战进行了系统研究。Ofte和Katsikas（2023）考察了操作人员的态势感知。

面对这些困难，AI越来越多地被视为对告警进行优先级排序、关联和归纳的手段。Chhetri等人（2024）在这方面研究了分析员与AI的协作。但AI被嵌入一个已经成形的环境之中，这个环境有其检测规则、工具和安全实践，没有任何理由假定AI的贡献在各个SOC之间是相同的。

1.1 所针对的研究空白

上述研究大多考察告警负荷、人机协作或态势感知。AI的效果与技术和组织环境质量之间的关联，则较少被形式化。本文的工作假设是：这一空白确实存在且十分重要；第5节所述的针对性综述须在投稿前对此加以证实或证伪。

分诊AI需要使用上下文：资产标识符、所有者、账号历史、补丁状态、终端安全态势，以及来自多个工具的日志。如果这些上下文不完整、不一致或分散，AI可能变得更快，却未必决策得更好。反之，一个管控良好的环境则可能使AI产生真实的收益。因此，上下文并非单纯的混杂变量：它可能决定我们所要衡量的那种效果。

1.2 研究问题

IT卫生成熟度、零信任实施的一致性以及工具碎片化程度，如何改变人工智能相对于传统分诊在SOC告警分诊中对检测质量和调查成本的影响?

该问题分解为三个子问题：

1. **SQ1（卫生）**。当IT卫生更成熟时，AI相对于传统分诊的优势是否更明显?
2. **SQ2（碎片化）**。当工具碎片化且互操作性差时，这一优势是否减弱，还是AI反而能够弥补这种碎片化?
3. **SQ3（零信任）**。对于与身份和访问相关的告警，一致的零信任实施是否会增大AI的优势?

两项结果须一并考察：以漏报威胁为代价换取的时间节省，并不构成改进。

1.3 贡献与结构

本文提供三方面内容：一个有别于告警数量和告警疲劳的信息噪声功能性定义；一个调节框架，其中AI是核心变量，环境的三个特征是调节变量；以及四项可证伪的命题和一个验证方案。第2节回顾文献，第3节介绍框架，第4节提出命题，第5节描

述验证方法，第6至8节分别为讨论、局限和结论。

2. 文献综述

本综述有意聚焦于支撑该模型的内容，仍属初步性质：第5节规定在投稿前开展可重复的综述。

2.1 告警数量与疲劳

告警疲劳是指分析员处理大量相关性低或难以判定的告警时，可能出现的注意力或警觉性下降（Tariq等人，2025）。告警数量衡量的是负荷，而不是工作的难度：两个收到同样数量告警的SOC，可能因可用上下文、冗余程度和调查流程的不同而面对截然不同的工作量。因此必须区分所收集事件的数量、所产生告警的数量、相关告警的比例、研判的难度以及最终决策的质量。

2.2 分诊中的AI与人机协作

AI可以对告警进行优先级排序、关联事件、归纳上下文并自动化重复性任务。Chhetri等人（2024）主张一种协作方式：由自动化处理适合的任务，而人类专业能力继续用于处理含糊不清的情形。然而，关于自动化的研究表明，过度信任和自满是已知的风险（Parasuraman和Riley，1997；Parasuraman和Manzey，2010）。因此，只有在漏掉相关威胁的风险没有增加的前提下，用更少时间处理更多告警的AI才算提升了安全性。这一保留意见说明了为何要同时衡量调查成本和检测质量。

2.3 工具碎片化与上下文丢失

SOC组合使用多种专用技术。这种多样性提高了覆盖面，但可能削弱集成：同一资产使用不同标识符、告警冗余、上下文须跨多个界面手工重建。Kokulu等人（2019）记录了SOC中技术、流程与人员之间的错配。相关变量不是产品的数量，而是互操作性、数据的语义一致性以及组件之间的上下文共享。由许多集成良好的工具构成的环境，按本模型的含义并不属于碎片化。

2.4 IT卫生

IT卫生涵盖维持环境可控的基本实践：资产清单、补丁管理、账号与权限管理、安全配置。ANSSI（2017）提出了一套参考措施。对SOC而言，这些实践决定了告警能多容易地关联到某项资产及其责任人，以及基线行为的稳定性。不过，卫生状况的改善可能揭示此前不可见的事件，并暂时增加检测数量；因此预期效应针对的是告警的可解释性，而不是告警的数量。

2.5 零信任

零信任建立在对访问的显式验证、最小权限，以及对每次请求的上下文和风险评估之上（Rose等人，2020）。CISA（2023）的成熟度模型将其实施划分为若干支柱，其中包括身份和终端。相关控制措施产生关于身份、设备和访问条件的信息，这些信息与其他来源关联后，有助于研判访问类告警。但协调不当的策略也可能增加拒绝次数和上下文切换。因此，零信任既不是噪声的内在来源，也不能保证减少噪声。在本模型中，它的作用仅限于与身份和访问相关的告警，在这类告警中它提供上下文。

2.6 综合与当前的文献支撑

下表针对模型的每个要素，列出其假定的作用以及本文目前所拥有的文献支撑程度，并标明需通过针对性综述加以巩固的部分。

要素	在模型中的假定作用	当前的文献支撑
告警疲劳与数量	控制变量	充分（Tariq等人，2025；Alahmadi等人，2022）
人机协作	辅助分诊的框架	部分（Chhetri等人，2024；Parasuraman和Manzey，2010）
工具碎片化	调节变量	部分，以定性为主（Kokulu等人，2019）
IT卫生	调节变量	有参考框架（ANSSI，2017），与SOC关联的研究很少
零信任	调节变量，身份与访问类告警	有参考框架（Rose等人，2020；CISA，2023），与SOC关联的研究很少
这些因素与AI之间的交互作用	贡献的核心	有待针对性综述确立

因此，研究空白与其说是每个因素都缺乏文献，不如说是就我们所知，缺少一个将它们作为AI对分诊影响的调节变量加以整合的框架。

3. 概念框架

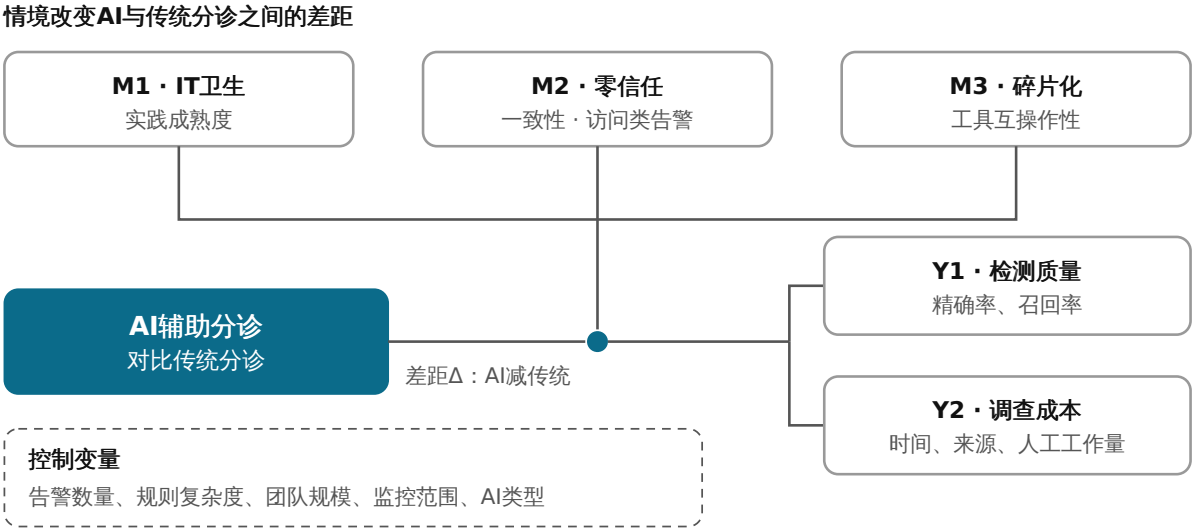
3.1 信息噪声的定义

信息噪声是指在特定运营情境下，安全信息中消耗分析资源、却未按比例有助于识别、研判或处置相关威胁的那一部分。

这一定义是功能性的。非恶意告警不一定是噪声：它可能验证某项控制的覆盖范围，或揭示配置错误。噪声要根据调查的目的、信号的价值以及利用该信号所需的努力来判断。它不同于信息量（一个量），也不同于告警疲劳（长期暴露于难以应付的负荷之下所可能产生的人为后果）。

3.2 模型变量

该模型提出的是一个关于差距的问题：AI是否比传统分诊做得更好或成本更低，这一差距是否随环境而变化？模型包含一个核心变量、三个调节变量、两项结果和一组控制变量。下图给出其结构，下表给出工作定义。



调节模型 · 1个核心变量，3个调节变量，2项结果

三个调节变量作用于AI与传统分诊之间的差距，而不是直接作用于结果；控制变量作用于被比较的两种条件。

角色	变量	工作定义
核心	AI辅助分诊	利用AI对告警进行优先级排序、关联或归纳，并与基于规则和人工流程的传统分诊相比较。以其功能、自动化程度和人工监督来描述。
调节变量M1	IT卫生成熟度	资产清单的完整性、补丁合规、账号与权限管控、配置的持续维护。
调节变量M2	零信任实施的一致性	访问策略的协调统一，以及身份与终端数据的整合。适用于与身份和访问相关的告警。
调节变量M3	工具碎片化	实际互操作性低：同一资产没有共同标识符、上下文分散、每条告警需查阅的界面数量多。
结果Y1	检测质量	相关告警上的精确率、召回率和漏报率。
结果Y2	调查成本	研判时间、查阅的数据来源数量、每条告警的人工工作量。
控制	数量与配置	告警数量、规则配置复杂度、团队规模与经验、受监控范围、AI类型。

3.3 对模型的解读

设Δ为AI辅助分诊与传统分诊之间的绩效差距，在Y1和Y2上分别衡量。调节变量是使Δ发生变化的变量：AI的效果不被假定为恒定，而被假定为有条件的。该模型并不断言AI总体上有效或无效，而是说明其效果在何处、在什么条件下发生变化。

对这一解读有三点说明。

1. 成熟度与一致性是两个不同的构念。卫生以实践的成熟度来衡量，零信任以架构及其策略的一致性来衡量。两者将分别操作化（第5节）。

2. 数量与规则复杂度是控制变量，而非研究对象。它们影响被比较的两种条件下的告警负荷，但本框架并不试图解释它们自身的效应。
3. 存在竞争性解读。卫生也可能作为改变告警数量的因素（直接效应）而起作用，而最成熟的SOC可能正是最先采用AI的那些（选择偏差）。第5节的方案规定在同一SOC内部进行比较，以限制后一种风险。

4. 研究命题

以下四项命题是有待检验的理论陈述，而非结果。每项命题均说明预期效应、作用机制以及何种情形将对其构成反驳。“AI的优势”针对每项结果，指相对于传统分诊而言有利于AI的差距：更高的检测质量或更低的调查成本。

P1. 基准效应：收益首先体现在成本上

陈述。平均而言，AI辅助分诊相对于传统分诊降低调查成本（Y2），但这一降低不足以证明检测质量（Y1）得到改善，Y1的差距可能为零、为正或为负。

机制。AI首先通过优先级排序和归纳来加快研判速度。检测质量则取决于排序的准确性，以及掩盖重要告警的风险，这是决策辅助系统已知的风险（Parasuraman和Manzey，2010）。

反驳。如果AI下成本并未降低，或者AI在Y1上的优势在所有环境中一律为正（这将使区分两项结果变得没有必要），则P1被反驳。

P2. IT卫生：优势随成熟度提高而增大

陈述。在控制告警数量的前提下，IT卫生成熟度（M1）越高，AI在Y1和Y2上的优势越大。

机制。完整的资产清单、受控的账号和稳定的配置，使AI能够将每条告警关联到某项资产及其责任人，并依托稳定的基线行为。

注意事项。更好的卫生状况可能揭示此前不可见的事件，并暂时增加检测数量；因此需要控制数量。

反驳。控制数量后，AI的使用与M1之间的交互作用为零或符号相反。

P3. 工具碎片化：优势减弱，或AI予以弥补

陈述。工具越碎片化、互操作性越差（M3），AI在Y1和Y2上的优势越小。

机制。不一致的标识符和分散的上下文限制了AI关联数据的能力；其输出于是建立在不完整的上下文之上。

竞争性命题。AI反而可能通过关联分散的数据源来弥补碎片化，而这些数据源否则需要分析员逐一查阅。这样，在碎片化的环境中优势会更明显。这两种解读相互对立，可以通过数据加以区分；将二者分出高下是本研究可能的贡献。

反驳。AI的使用与M3之间的交互作用为零或为正。交互作用为正则支持竞争性解读。

P4. 零信任：优势随一致性提高而增大，限于访问类告警

陈述。对于与身份和访问相关的告警，零信任实施（M2）越一致，即策略越协调、身份与终端数据越整合，AI在Y1和Y2上的优势越大。

机制。零信任控制措施为研判访问类告警提供可用的上下文：终端安全态势、会话风险、所执行的访问决策。

注意事项。协调不当的策略可能增加拒绝次数和上下文切换，并削弱零信任对分诊的贡献。

反驳。这些告警上没有交互作用，或者与访问无关的告警上出现同等程度的交互作用。后一种情形将表明，所测量的构念反映的是整体成熟度，而不是零信任。

综合

三个调节变量的叠加（高阶交互作用）不作为命题提出，而是作为探索性问题在第7节中处理。

命题	因素	对AI优势的预期效应	涉及的告警
P1	无（基准效应）	在Y2上有优势；在Y1上的优势尚未确立	全部
P2	M1 IT卫生	随成熟度提高而增大	全部
P3	M3 工具碎片化	随碎片化加剧而减小（竞争性解读：增大）	全部
P4	M2 零信任	随一致性提高而增大	身份与访问

5. 拟议的验证方法

验证分为三个阶段，从探索性最强到约束性最强。贯穿其中的是同一逻辑：在卫生、零信任和碎片化程度各不相同的情境内部，比较AI与传统分诊。

5.1 阶段0. 可重复的针对性综述

一项范围受限的系统综述，按PRISMA　2020（Page等人，2021）报告，将核实第1.1节所宣称的研究空白。该综述将查询SOC、告警分诊、AI、IT卫生、零信任和工具集成之间的交叉领域，并记录所用数据库、检索式、纳入标准和筛选过程。其结果决定贡献的最终表述。

5.2 阶段1. 探索性定性研究

将对SOC分析员、检测负责人、CISO和工具集成专家开展半结构化访谈。建议在4至6个不同的SOC（内部、服务商、公共和私营部门）中进行约12至20次访谈，直至主题饱和。访谈将检验调节变量是否对应真实机制、工作定义是否可操作，并收集AI帮助或妨碍分诊的实例。

5.3 阶段2. 多层次分析与受控回放

多层次分析。告警（第1层）嵌套于SOC或客户范围（第2层）之中。调节变量M1、M2和M3在第2层测量；AI的使用在可能时于同一SOC内部变化（部署前后、有AI与无AI的处理队列）。估计带有第1层与第2层之间交互项的混合模型（Raudenbush和Bryk，2002；Hayes，2018）。第2层交互作用的统计功效取决于SOC或范围的数量，而不是告警的数量。如果该数量不足以估计三个交互作用，研究将保留两个调节变量；而同时监管多个成熟度不同的客户的托管服务提供商，则是值得探索的天然变异来源。

受控回放。一组由专家标注的告警作为基准真值。分析员在有或无AI辅助的情况下处理这些告警，同时改变所提供上下文的质量（完整或受损的清单、有无共同标识符、身份数据是否整合）。这种操纵使我们能够接近调节变量对AI优势的因果效应，而仅凭生产数据无法确立这一点。注入场景（例如来自攻击模拟演练）补充该方案，用以估计在生产环境中无法观测的召回率。

5.4 操作化

指标将在数据收集之前确定。只有在召回率没有下降的情况下，告警数量或处理时间的减少才会被解释为收益。

构念	拟采用的指标	来源
AI辅助分诊	辅助功能、自动化程度、人工监督、被修正的建议所占比例	访谈、工具日志
M1 卫生	受ANSSI（2017）措施启发的综合得分：清单覆盖率、补丁合规、账号与权限审查	审计、资产管理数据
M2 零信任	受CISA（2023）模型的身份和终端支柱以及Rose等人（2020）原则启发的量表：策略一致性、数据整合	审计、架构文档
M3 碎片化	每条告警查阅的界面数量、在共同标识符下完成解析的资产比例、获取上下文的时延	观察、日志
Y1 检测质量	精确率、召回率、漏报率	标注数据集、注入场景
Y2 调查成本	研判时间中位数、交叉查阅次数、人工工作量	日志、计时
控制	告警数量、规则复杂度、团队规模与经验、范围、AI类型	运营数据

5.5 分析策略

描述性分析将刻画数量、分布以及不同情境之间的差异。混合模型将检验AI的使用与每个调节变量之间的交互作用，并设置按SOC划分的随机效应和控制变量；P4仅在身份与访问类告警上估计，然后与其他告警比较，作为特异性检验。敏感性分析将改变指标的定义，并对多重比较进行校正。由于AI的部署并非随机，且最成熟的SOC可能最先采用，成熟度被显式建模，并优先采用同一SOC内部的比较。在数据收集之前，无法预期任何结果。

5.6 伦理与保密

告警数据较为敏感，可能包含个人数据。研究将要求与各组织签订保密协议，对日志进行匿名化或假名化处理，并对处理时间使用汇总数据，以免对分析员进行个体评价。访谈将取得知情同意。

6. 讨论

6.1 理论贡献

该框架将研究问题从数量转向AI的条件性价值。它不是问AI是否减轻告警疲劳，而是问在何种情境下AI能够改善检测并降低调查成本。这一重新表述带来三点后果。

1. AI被视为嵌入环境之中的处理能力，而不是孤立的解决方案。其效果是有条件的，而被检验的正是这种条件性。
2. 生产率的提升不等于安全性的提升。通过同时衡量Y1和Y2，该框架避免了对一个缩短处理时间却放过更多威胁的AI作出性能良好的结论。
3. 竞争性解读从一开始就被提出。就碎片化而言，P3及其竞争性命题预测相反的符号，这使该框架在从业者直觉出现分歧的问题上具有可证伪性。

6.2 对网络安全治理的启示

安全负责人和SOC负责人可以从该框架中得到一套诊断表，供其在投资一层AI之前使用。所观察到的困难，是源于校准不当的规则、不完整的清单、管控不善的账号、互不兼容的工具，还是缺乏流程？如果答案在于环境，AI就有可能只带来速度的提升而没有检测的改善，并使人们更难发现它所自动化的缺陷。

该框架还建议，在数量指标之外补充相关性、上下文、研判成本和决策绩效方面的衡量，并将含糊不清的情形留给人工监督。它并不反对创新：它试图确定创新在何种条件下能够带来可衡量的改善。

6.3 投资的先后次序

如果P2和P4得到验证，IT卫生和零信任的一致性就不仅是各自独立的安全目标：它们还提高了对检测类AI投资的回报。如果P3得到支持，工具集成应先于AI。如果竞争性命题占上风，AI反而可能成为缓解碎片化的短期权宜之计。无论哪种情形，投资决策都宜以对情境的诊断为依据，而不是仅凭工具的承诺。

7. 局限与展望

7.1 局限

稿件的性质。本文属于概念性研究。它不基于任何原始数据，其命题尚未得到证实。文献综述是初步的，须由阶段0的可重复综述取代。

构念效度。卫生、零信任的一致性和碎片化都是复合构念，其测量取决于情境。所提出的量表受到一些参考框架（ANSSI，2017；CISA，2023）的启发，而这些框架并非为衡量AI效果的调节变量而设计，需要加以验证。

零信任的适用范围。调节变量M2仅适用于身份与访问类告警，对其他类别告警的分诊则无从说明。

基准真值。精确率和召回率需要关于相关事件的可靠参照。在生产环境中，召回率无法观测，只能依赖注入场景，而其代表性有限。

选择与因果。AI的部署并非随机。同一SOC内部的比较和受控回放限制了偏差，但无法消除它。

AI的异质性。机器学习分类器、关联引擎和基于语言模型的助手，其优势与缺陷各不相同，且更新迅速。AI类型被作为控制变量，但其结果未必能从一代工具推广到下一代。

可推广性。内部SOC、服务提供商和公共机构在资源和目标上各不相同。比较时必须考虑这一点。

7.2 展望

高阶交互作用。三个调节变量的效应是相互叠加、相互抵消，还是其中一个就已足够？这是一个探索性问题，需要比初次研究更大的样本。

时间维度。成熟度是不断演变的。纵向研究可以追踪当卫生、零信任或工具集成得到改善时，AI优势的变化。

人的因素。人工监督、过度信任和自满对Y1的影响，可以建模为一个额外的中介变量或调节变量。

对手的适应。分诊AI本身可能成为攻击目标。将该框架扩展到针对检测的攻击下的稳健性问题，值得另行研究。

8. 结论

本文建议将对告警疲劳的分析，从数量转向人工智能的条件性价值。它提出了一个明确的问题：IT卫生、零信任的一致性和工具碎片化，是否以及如何改变AI对分诊的影响，包括检测质量和调查成本两个方面。

核心命题是：AI在SOC中的运营价值，不仅取决于其自身能力，还取决于其所处环境在配置、集成和上下文方面的质量。四项可证伪的命题（其中一项对立了对碎片化效应的两种解读）以及一个三阶段方案，使这一命题得以接受检验。

如果它得到验证，在增加一层AI之前应当提出的问题，就不再仅仅是工具能做什么，而是环境允许它做什么。如果它被反驳，该框架至少澄清了AI在何种条件下能够不受情境影响地带来可衡量的收益，这同样是一个有用的结果。

参考文献

Agence nationale de la sécurité des systèmes d’information (ANSSI). (2017). Guide d’hygiène informatique : renforcer la sécurité de son système d’information en 42 mesures (version 2.0). ANSSI.

Alahmadi, B. A., Axon, L., & Martinovic, I. (2022). 99% false positives: A qualitative study of SOC analysts’ perspectives on security alarms. Proceedings of the 31st USENIX Security Symposium. USENIX Association.

Chhetri, M. B., Tariq, S., Singh, R., Jalalvand, F., Paris, C., & Nepal, S. (2024). Towards human-AI teaming to mitigate alert fatigue in Security Operations Centres. ACM Transactions on Internet Technology, 24(3), Article 12, 1–22. https://doi.org/10.1145/3670009

Cybersecurity and Infrastructure Security Agency (CISA). (2023). Zero Trust Maturity Model, Version 2.0. CISA.

Hayes, A. F. (2018). Introduction to mediation, moderation, and conditional process analysis: A regression-based approach (2nd ed.). Guilford Press.

Kokulu, F. B., Soneji, A., Bao, T., Shoshitaishvili, Y., Zhao, Z., Doupé, A., & Ahn, G.-J. (2019). Matched and mismatched SOCs: A qualitative study on Security Operations Center issues. Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security. ACM.

Ofte, H. J., & Katsikas, S. (2023). Understanding situation awareness in SOCs: A systematic literature review. Computers & Security, 126, 103069. https://doi.org/10.1016/j.cose.2022.103069

Page, M. J., McKenzie, J. E., Bossuyt, P. M., Boutron, I., Hoffmann, T. C., Mulrow, C. D., et al. (2021). The PRISMA 2020 statement: An updated guideline for reporting systematic reviews. BMJ, 372, n71. https://doi.org/10.1136/bmj.n71

Parasuraman, R., & Manzey, D. H. (2010). Complacency and bias in human use of automation: An attentional integration. Human Factors, 52(3), 381–410.

Parasuraman, R., & Riley, V. (1997). Humans and automation: Use, misuse, disuse, abuse. Human Factors, 39(2), 230–253.

Raudenbush, S. W., & Bryk, A. S. (2002). Hierarchical linear models: Applications and data analysis methods (2nd ed.). Sage.

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero Trust Architecture (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Tariq, S., Baruwal Chhetri, M., Nepal, S., & Paris, C. (2025). Alert fatigue in Security Operations Centres: Research challenges and opportunities. ACM Computing Surveys, 57(9), Article 224, 1–38. https://doi.org/10.1145/3723158

Vielberth, M., Böhm, F., Fichtinger, I., & Pernul, G. (2020). Security Operations Center: A systematic study and open challenges. IEEE Access, 8, 227756–227779.